

Esercizio 6: Estrazione eseguibile da PCAP

Executive Summary

Il seguente report illustra le procedure di analisi di un file **pcap** tramite **Wireshark** e l'estrazione dell'eseguibile **W32.Nimda.Amm.exe** dalla cattura.

Obiettivi

- **Parte 1:** Analizzare Log e Catture di Traffico Pre-catturati
- **Parte 2:** Estrarre File Scaricati dal PCAP

Parte 1: Analizzare Log e Catture di Traffico Pre-catturati

La cattura nel file **"nimda.download.pcap"** rappresenta il traffico di rete per il download di un file eseguibile tramite protocollo HTTP:

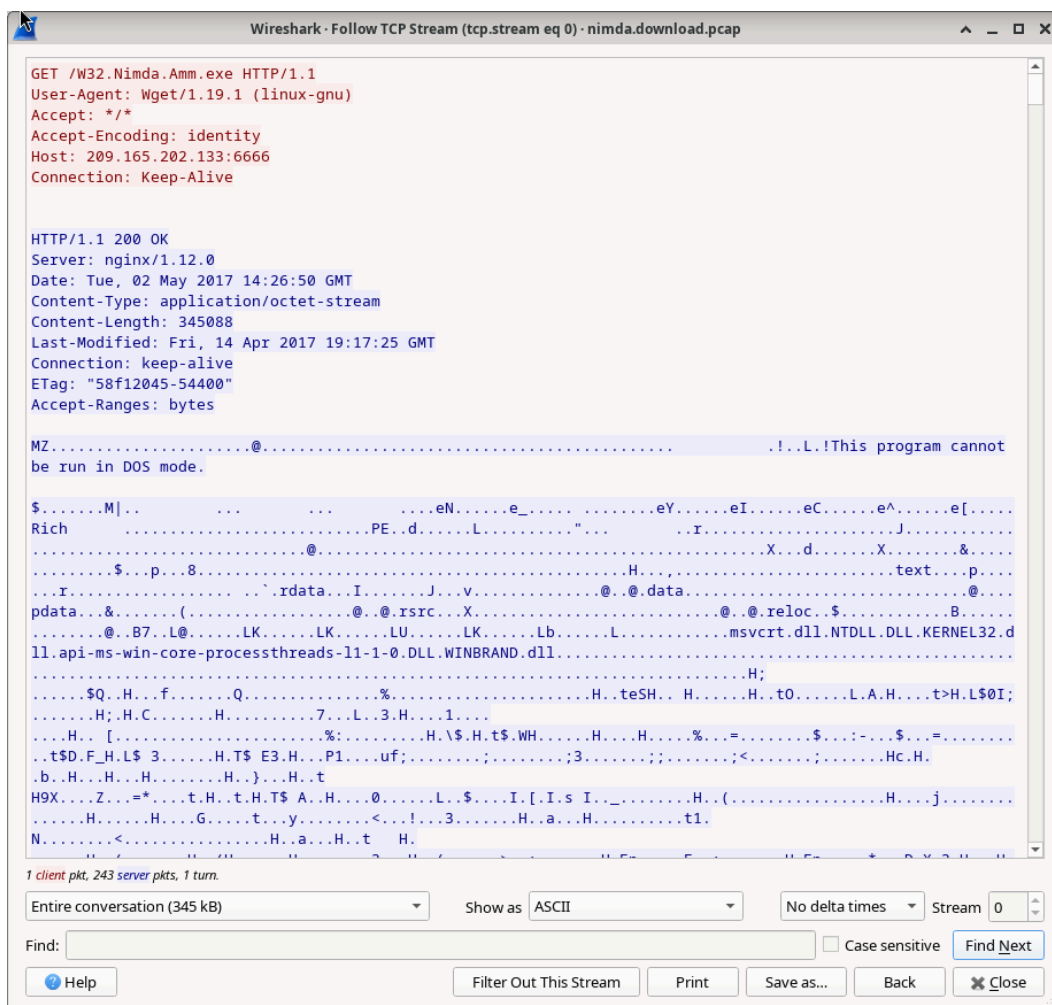
The screenshot displays the Wireshark interface with the file **nimda.download.pcap** open. The packet list on the left shows a series of TCP and HTTP packets. The selected packet (No. 4) is an HTTP GET request for **W32.Nimda.Amm.exe**. The packet details on the right show the structure of the HTTP request, including the status bar indicating **200 OK**. The packet bytes on the bottom show the raw data of the captured packet.

- **Handshake TCP (righe 1-3):** Apertura della connessione tra client e server sulla porta 6666 con 3-Way Handshake
- **Richiesta HTTP (riga 4):** Il client chiede di scaricare il file *W32.Nimda.Amm.exe*.
- **Trasferimento Dati (righe 5-308):** Il file viene inviato a pezzi (segmenti TCP).
- **Conferma e Chiusura (riga 309-316):** Il server invia l'OK finale (200 OK) e la connessione viene chiusa dopo il completamento.

Domanda 1

Cosa sono tutti quei simboli mostrati nella finestra Follow TCP Stream? Sono rumore di connessione? Dati? Spiega.

Quei simboli rappresentano la traduzione testuale (ASCII) di dati binari, non si tratta quindi di rumore di connessione.



Domanda 2

Ci sono alcune parole leggibili sparse tra i simboli. Perché sono lì?

Un file .exe è un file eseguibile che contiene istruzioni in codice macchina. Questi dati non sono pensati per essere letti come testo per il linguaggio umano pertanto Wireshark cerca di visualizzare ogni byte come un carattere: se un byte corrisponde a una lettera o un numero verrà visualizzato, se non corrisponde a nulla di leggibile, mostra un punto o simboli.

In sostanza, ciò che viene mostrato è il corpo del programma nel suo formato grezzo mentre attraversa la rete.

Domanda Sfida

Nonostante il nome W32.Nimda.Amm.exe, questo eseguibile non è il famoso worm. Per motivi di sicurezza, questo è un altro file eseguibile che è stato rinominato come W32.Nimda.Amm.exe. Usando i frammenti di parole visualizzati dalla finestra Follow TCP Stream di Wireshark, puoi dire quale eseguibile sia realmente?

In base all'analisi delle stringhe contenute nel flusso TCP, l'eseguibile reale è **cmd.exe**, ovvero il Prompt dei comandi di Windows rinominato come **W32.Nimda.Amm.exe**

```
...<?xml version="1.0" encoding="UTF-8" standalone="yes"?>
<!-- Copyright (c) Microsoft Corporation -->
<assembly xmlns="urn:schemas-microsoft-com:asm.v1" manifestVersion="1.0">
  <assemblyIdentity
    version="5.1.0.0"
    processorArchitecture="amd64"
    name="Microsoft.Windows.FileSystem.CMD"
    type="win32"
  />
  <description>Windows Command Processor</description>

  <trustInfo xmlns="urn:schemas-microsoft-com:asm.v3">
    <security>
      <requestedPrivileges>
        <requestedExecutionLevel
          level="asInvoker"
          uiAccess="false"
        />
      </requestedPrivileges>
    </security>
  </trustInfo>
```

Parte 2: Estrarre File Scaricati dal PCAP

Domanda 3

Perché W32.Nimda.Amm.exe è l'unico file nella cattura?

La cattura in questione non è l'intero traffico della rete ma un singolo flusso TCP relativo, in questo caso, alla conversazione tra un client e un server. Poiché la connessione è stata aperta esclusivamente per scaricare quel file via HTTP, non si vedranno altri file o navigazioni web nello stesso elenco.

Inoltre, come indicato nel campo *User-Agent*, il download è stato effettuato con metodo Wget. A differenza di un browser che scarica contemporaneamente icone, script e immagini per visualizzare una pagina, Wget, essendo uno strumento da riga di comando, scarica solo il file specifico indicato nell'URL.

```
▶ Frame 4: 230 bytes on wire (1840 bits), 230 bytes captured (1840 bits)
▶ Ethernet II, Src: ea:05:2c:e1:90:3d (ea:05:2c:e1:90:3d), Dst: 16:4c:37:9e:eb:50 (16:4c:37:9e:eb:50)
▶ Internet Protocol Version 4, Src: 209.165.200.235, Dst: 209.165.202.133
▶ Transmission Control Protocol, Src Port: 48598, Dst Port: 6666, Seq: 1, Ack: 1, Len: 164
▼ Hypertext Transfer Protocol
  ▶ GET /W32.Nimda.Amm.exe HTTP/1.1\r\n
    User-Agent: Wget/1.19.1 (linux-gnu)\r\n
    Accept: */*\r\n
    Accept-Encoding: identity\r\n
    Host: 209.165.202.133:6666\r\n
    Connection: Keep-Alive\r\n
    \r\n
    [Response in frame: 309]
    [Full request URI: http://209.165.202.133:6666/W32.Nimda.Amm.exe]
```

Domanda 4

Il file è stato salvato?

Sì, il file è stato salvato.

Domanda 5

Nel processo di analisi del malware, quale sarebbe un probabile passo successivo per un analista di sicurezza?

Il passo successivo per un analista di sicurezza consiste nell'analisi statica e dinamica del file estratto.